

Clase 183 — SIEM: arquitectura y componentes

Parte: 8 — Blue Team, detección y SOC · Fuente: Blue Team Handbook: SOC, SIEM, and Threat Hunting Use Cases — Don Murdoch 🕒 Duración estimada: 100 min · Nivel: Intermedio

🎯 Objetivo

Comprender qué es un SIEM (Security Information and Event Management), de qué piezas se compone y cómo fluye un evento desde la recolección hasta la alerta. Entenderás las decisiones de arquitectura (ingesta, parsing, indexación, correlación, retención) que determinan si un SIEM detecta o solo acumula datos.

📊 Resultados de aprendizaje

Al finalizar, el alumno podrá:

- 1. **Describir** la tubería de un SIEM: colección → normalización → indexación → correlación → alertas.
- 2. **Diferenciar** SIEM de un simple almacén de logs y de un EDR/XDR.
- 3. **Explicar** parsing, enriquecimiento y esquemas de datos.
- 4. **Dimensionar** ingesta (EPS/GB por día) y su impacto en licencia y hardware.
- 5. **Valorar** modelos de despliegue: on-prem, cloud-native y SIEM as a Service.

📖 Temas

#	Tema	Por qué importa
1	Definición y funciones del SIEM	Clarifica su rol en el SOC
2	Pipeline de ingesta	Determina qué datos entran y en qué forma
3	Parsing y normalización	Sin campos limpios no hay correlación
4	Enriquecimiento (GeoIP, threat intel, activos)	Convierte datos en contexto
5	Motor de correlación y reglas	El corazón de la detección
6	Indexación, búsqueda y retención	Afecta velocidad y coste
7	Dimensionamiento (EPS, GB/día)	Base del presupuesto y la licencia
8	Modelos de despliegue	On-prem vs cloud vs gestionado

📖 Definiciones y características

- **SIEM:** plataforma que centraliza, normaliza y correlaciona eventos de seguridad para detectar, investigar y reportar. Característica: correlación entre múltiples fuentes en tiempo casi real.
- **Colector/forwarder:** agente o servicio que recibe y reenvía logs (Universal Forwarder de Splunk, Beats de Elastic). Característica: puede filtrar y enrutar en origen.

- **Parser:** convierte texto crudo en campos estructurados (`src_ip` , `user` , `event_id`). Característica: específico por tipo de fuente.
- **Enriquecimiento:** añade contexto externo (geolocalización, reputación, propietario del activo). Característica: aumenta la precisión del triaje.
- **Regla de correlación:** lógica que dispara una alerta al cumplirse condiciones sobre uno o varios eventos. Característica: puede ser umbral, secuencia o anomalía.
- **EPS (Events Per Second):** volumen de eventos por segundo. Característica: métrica de dimensionamiento y licenciamiento.
- **Retención caliente/fría:** datos recientes rápidos de consultar (hot) vs históricos baratos (cold). Característica: equilibrio coste/velocidad.

Herramientas y preparación

Para experimentar la arquitectura, prepara en laboratorio aislado uno de estos stacks:

- **Splunk Free/Enterprise Trial** con un Universal Forwarder enviando datos.
- **Elastic Stack** (Elasticsearch + Logstash/Beats + Kibana) vía Docker Compose.
- **Wazuh** (indexer + manager + dashboard) para un SIEM open source completo.

Reutiliza la telemetría de la clase 182 (Sysmon, Zeek) como fuente de ingesta. Trabaja siempre en tu red de laboratorio.

Laboratorio guiado — Traza un evento de punta a punta

1. **Levanta el SIEM.** Con Docker Compose despliega Elastic (o instala Splunk Free). Confirma acceso a Kibana/Splunk Web.
2. **Conecta una fuente.** Reenvía los Sysmon/Event Logs del Windows de laboratorio con Winlogbeat/Universal Forwarder.
3. **Verifica el parsing.** Busca un evento de creación de proceso y comprueba que campos como `process.command_line` o `Image` están extraídos, no en texto plano.
4. **Añade enriquecimiento.** Configura un pipeline que agregue GeoIP a las IP públicas (Logstash `geoip` o Splunk `iplocation`).
5. **Escribe una correlación simple.** Regla que alerte ante 5 fallos de autenticación (Event ID 4625) seguidos de un éxito (4624) para el mismo usuario en 5 minutos.
6. **Mide la ingesta.** Observa EPS/GB por día en el panel de monitoreo del SIEM y proyecta el volumen a 30 días.
7. **Prueba retención.** Configura un índice con política de ciclo de vida (ILM en Elastic) que mueva datos a fase fría a los 7 días.

Ejercicios

1. Dibuja el pipeline completo de tu SIEM con cada componente etiquetado.
2. Calcula el GB/día si ingestas 2.000 EPS con un tamaño medio de evento de 800 bytes.
3. Escribe el parser (regex o pipeline) para una línea de log de tu firewall.
4. Compara SIEM on-prem vs cloud-native con 4 criterios (coste, escalado, control, mantenimiento).
5. Diseña un esquema de enriquecimiento con 3 fuentes de contexto.
6. Justifica una política hot/warm/cold para 90 días de retención.

Reto verificable

Documenta el recorrido de un evento real de tu laboratorio: captura de pantalla del dato crudo, del dato parseado con sus campos, del enriquecimiento aplicado y de la alerta correlacionada que dispara. **Criterio de aceptación:** la regla de correlación de fuerza bruta (múltiples 4625 + un 4624) dispara una alerta en el SIEM y puedes explicar en qué índice quedó y cuánto tiempo se retiene.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
Eventos llegan como texto plano	Falta parser para esa fuente; crea/asigna el sourcetype
Licencia excedida en Splunk	Ingesta mayor a lo contratado; filtra ruido en el forwarder
Búsquedas lentísimas	Retención mal segmentada; usa índices y fases hot/cold
Alertas duplicadas	Correlación sin dedup ni throttling; añade ventana de supresión
GeolP vacío	Base de datos GeolP no instalada/actualizada; refresca el feed

Preguntas frecuentes

? ¿SIEM o data lake? El SIEM prioriza correlación y alertas en tiempo real; el data lake, almacenamiento masivo barato. Muchas arquitecturas modernas combinan ambos (SIEM para lo caliente, lake para histórico).

? ¿El SIEM reemplaza al EDR? No. El EDR ve el endpoint en profundidad y responde; el SIEM correlaciona todas las fuentes. Se complementan; el EDR suele ser una fuente del SIEM.

? ¿Cómo evito que el SIEM se vuelva un basurero de logs? Ingesta con propósito de detección, no por acumular. Cada fuente debe respaldar al menos un caso de uso de detección o hunting.

Referencias

- Murdoch, D. *Blue Team Handbook: SOC, SIEM, and Threat Hunting Use Cases*.
- Gartner, "Magic Quadrant for SIEM" (marco conceptual de capacidades).
- Elastic SIEM/Security docs — <https://www.elastic.co/security>
- Splunk Docs, "How indexing works" — <https://docs.splunk.com/>
- Wazuh Documentation — <https://documentation.wazuh.com/>

Siguiente clase

Clase 184 - Splunk para deteccion